



Incident Response Report

ID: 2025-HSS-IR-002

**Ryan Coyle
Incident Response Team**

Notice: This document was created as part of a fictional cybersecurity capstone scenario. HealthSecure Systems (HSS), all users, systems, IP addresses, incident data, and business information shown are simulated and intended solely for educational portfolio use.

Index

Executive Summary.....	2
Summary of Major Actions Taken.....	2
Key Recommendations.....	3
Preparation.....	3
Roles and Responsibilities.....	4
Existing Tools and Capabilities.....	4
Strengths in Current Preparation.....	5
Gaps in Preparedness.....	5
Preparation Improvements.....	6
Detection and Identification.....	6
Indicators of Compromise - See Appendix A.....	7
Log and Alert Analysis.....	7
Incident/Response Timeline - See Appendix B.....	7
Incident Scope.....	7
Severity Assessment.....	8
Containment.....	9
Short-Term Containment Actions: 0–6 Hours.....	9
Mid-Term Containment Actions: 6–24 Hours.....	9
Long-Term Containment Strategy.....	10
Eradication.....	11
Root Cause Analysis.....	11
Short-Term Eradication Actions: 0–6 Hours.....	11
Mid-Term Eradication Actions: 6–24 Hours.....	12
Recovery.....	12
Restoration Process.....	13
Verification Steps.....	13
Post-Recovery Monitoring.....	14
Post-Incident Review.....	15
What Worked Well.....	15
Areas for Improvement.....	15
Updated IR Plan Recommendations.....	16
Continuous Improvement.....	16
Process Refinements.....	16
New Security Measures.....	17
Training Recommendations.....	17
Conclusion.....	18
Summary of Actions.....	18
Key Recommendations.....	19
Appendix A.....	20
Indicators of Compromise:.....	20
Appendix B.....	21
Incident/Response Timeline:.....	21

Executive Summary

Incident ID: 2025-HSS-IR-002

Incident Severity: High (P2)

Incident Status: Resolved

Organization Overview and Critical Systems: HealthSecure Systems (HSS) is a regional healthcare software provider that supports electronic health record services for healthcare clients. Because HSS handles sensitive business, payroll, patient-related, and development data, its critical systems include Finance workstations, HR data systems, Development DMZ systems, authentication services, and security monitoring tools.

Incident Overview: On April 12, 2025, at approximately 01:24 EST, Snort IDS alerts identified suspicious activity from Workstation-23, a Finance department workstation using IP address 192.168.1.45. The activity included signs of PsExec use, suspicious PowerShell execution, outbound communication to a suspicious external destination, and later activity toward internal systems. The investigation determined that the incident involved confirmed compromise of Workstation-23, with HR-SQL01 treated as compromised and attempted access to DevAppServe. See Appendix A for a complete list of the Indicators of Compromise (IoCs).

What was impacted: The impacted systems are Workstation-23 and HR-SQL01. Workstation-23 is compromised based on suspicious PowerShell activity, PsExec activity, outbound communication, and movement toward internal systems. HR-SQL01 is treated as compromised because Zeek logs confirm an SMB connection and an RDP session initiated from Workstation-23 to HR-SQL01 during the incident window.

DevAppServer is not confirmed compromised because the evidence shows an attempted SSH login, but no successful access. DevAppServer should still be treated as high-risk because it contains development artifacts and proprietary healthcare application resources. HR-SQL01 is especially sensitive because it contains payroll and PII data. At this time, there is no confirmed evidence that payroll data, PII, or development assets were accessed, altered, or exfiltrated.

Root Cause: The root cause is a payroll-themed phishing email sent to a Finance user. The phishing email directed the user to a disguised time sensitive file link, and shortly after, Workstation-23 showed suspicious PowerShell activity used to download a payload. The incident also involves credential misuse connected to the former employee account jcampbell, whose credentials appear in the cached credential store on Workstation-23. HSS's manual offboarding process, active former employee accounts, incomplete PowerShell logging, lack of centralized SIEM visibility, and possible EDR coverage gaps likely increased the organization's exposure and slowed investigation.

Summary of Major Actions Taken

The incident response process included the following major investigative, containment, eradication, and recovery actions: (see Appendix B for complete Incident/Response timeline)

- Reviewed key evidence, including Snort alerts, Zeek network logs, Windows Event Logs, phishing email evidence, asset inventory data, and forensic updates.
- Identified Workstation-23 and HR-SQL01 as compromised systems, and identified DevAppServer as a high-risk system that was targeted but not confirmed compromised.
- Isolated Workstation-23, blocked malicious IPs and domains, disabled risky accounts, and preserved forensic evidence.
- Coordinated with Legal and Compliance because the incident involved systems connected to payroll, PII, and potential regulatory exposure.
- Applied temporary firewall restrictions and stricter access controls for HR, DMZ, SMB, RDP, and SSH traffic.
- Removed malicious activity and artifacts, including malicious PowerShell activity, PsExec service activity, and the suspicious payload.
- Validated affected systems through EDR scans, event log review, data integrity checks, patching, and functional/security testing.
- Restored services in deliberate phases, enforced multi-factor authentication, expanded monitoring for repeat activity, and updated IR runbooks based on findings

Key Recommendations

The most critical improvements needed to strengthen HSS's security posture are:

- Automate employee offboarding and perform regular access reviews to reduce the risk of stale or former employee accounts being reused.
- Implement centralized logging through a SIEM or similar process, standardize EDR coverage across Windows, Linux, and DMZ systems, and enable PowerShell logging across all Windows endpoints.
- Strengthen phishing readiness, update the incident response playbook, improve network segmentation, and conduct regular tabletop exercises to prepare the team for future incidents.

Overall, this incident shows that HSS has useful detection tools, but the organization needs stronger account management, centralized visibility, endpoint monitoring, phishing defenses, and incident response readiness. Addressing these gaps should reduce the chance of recurrence, improve response speed, and better protect HSS's operations, compliance posture, and client trust.

Preparation

The Preparation section evaluates how ready HSS was to detect, investigate, and respond to this incident before and during the breach. HSS had a defined incident response team, several monitoring tools, and some network segmentation in place. However, the evidence also shows readiness gaps in centralized logging, offboarding, PowerShell visibility, endpoint monitoring, phishing readiness, and incident response practice.

Roles and Responsibilities

SOC Analyst:

The SOC Analyst is responsible for monitoring security alerts, reviewing suspicious activity, and helping determine whether an event should be escalated as a true security incident. During this incident, the SOC Analyst focused mainly on detection and analysis. This included reviewing Snort alerts, identifying suspicious activity from Workstation-23, monitoring Zeek and Snort data, and helping confirm whether containment actions were stopping additional suspicious activity.

Forensics Specialist:

The Forensics Specialist is responsible for deeper technical analysis of affected systems and evidence. This role focuses on preserving and examining host-level artifacts, suspicious files, credentials, memory evidence, logs, and attacker behavior. During this incident, the Forensics Specialist performed more granular analysis of Workstation-23, reviewed the suspicious PowerShell payload, investigated cached jcampbell credentials, extracted malicious artifacts for review, and helped determine whether additional systems showed signs of compromise.

IT Operations Lead:

The IT Operations Lead is the central operational role during the response. This role is responsible for executing most of the hands-on technical actions needed to contain, eradicate, and recover from the incident. During this incident, the IT Operations Lead isolated Workstation-23, blocked malicious IPs and domains, disabled risky accounts, applied temporary firewall restrictions, enforced stricter SMB/RDP/SSH access controls, supported removal of malicious activity, applied system patches, restored systems to secure settings, coordinated phased service restoration, and worked with system owners to keep critical operations running safely.

Existing Tools and Capabilities

At the time of the incident, HSS had several security and logging tools available, including Snort IDS, Zeek network monitoring, Windows Event Logs, Bitdefender EDR, asset inventory records, and an internal honeypot in the Development DMZ. HSS also had access to key evidence sources, including the phishing email extract and forensic updates. Together, these sources helped the team identify the incident timeline, affected systems, suspicious activity, and initial indicators of compromise.

HSS also had segmented environments for Finance, HR, Development, and IT Administration. This is a positive starting point because segmentation can limit how far an attacker can move if one system is compromised. However, this incident shows that access controls between sensitive systems still needed improvement because Workstation-23 was able to reach HR-SQL01 and attempt access to DevAppServer.

Strengths in Current Preparation

A major strength in HSS's preparation is that existing monitoring tools detected suspicious activity. Snort detected suspicious activity and possible lateral movement. Zeek showed network connections from Workstation-23 to HR-SQL01, DevAppServer, and a suspicious external IP address. Windows logs showed suspicious PowerShell and PsExec activity. The honeypot helped identify an unauthorized attempt to access the Development DMZ.

Another strength is that HSS had a small but defined incident response team. Even though the team is lean, the presence of a SOC Analyst, Forensics Specialist, and IT Operations Lead provided a basic structure for detection, evidence review, containment, eradication, and recovery.

Gaps in Preparedness

HSS had several preparation gaps that increased the organization's risk and made the investigation more difficult.

First, HSS did not have a centralized SIEM. Instead, the team had to review separate logs from Snort, Zeek, Windows systems, EDR, honeypot alerts, and forensic updates. For a three-person incident response team, this creates delays because the team must manually connect evidence from multiple sources.

Second, the incident response playbook had not been recently updated or tested through tabletop exercises. This is a concern because tabletop exercises help teams practice roles, communication, escalation, legal/compliance coordination, and recovery decisions before a real incident occurs.

Third, employee offboarding was handled manually by HR and IT. The internal audit showed that four former employee accounts were still active. This is a major concern because the incident involved the former employee account jcampbell, and those credentials were found cached on Workstation-23.

Fourth, PowerShell logging was disabled on about 30% of Windows machines due to a policy misconfiguration. Since PowerShell was used to download the suspicious payload in this incident, inconsistent PowerShell logging could make it harder to investigate similar activity across the environment.

Fifth, there was a possible endpoint monitoring gap for Linux or DMZ systems. The attempted access to DevAppServer did not trigger an EDR alert, which suggests HSS may not have consistent visibility across all critical systems.

Finally, HSS had not conducted recent phishing simulations. Since the attack vector was a payroll-themed phishing email, this shows a gap in employee awareness training and incident response readiness.

Preparation Improvements

To improve readiness, HSS should update and test its incident response playbook. The updated playbook should include clear steps for phishing attacks, credential misuse, suspicious PowerShell activity, PsExec activity, and lateral movement attempts.

HSS should implement a centralized SIEM or centralized log review process. This would allow the small security team to connect alerts from Snort, Zeek, Windows logs, EDR, honeypot data, and authentication activity faster.

Account offboarding should be automated so employee accounts are disabled immediately when someone leaves the organization. HSS should also perform regular access reviews to identify stale accounts, cached credentials, and unnecessary privileges.

PowerShell logging should be enabled across all Windows machines. This would improve visibility into suspicious script activity and support faster investigations.

HSS should review and standardize EDR coverage across Windows, Linux, and DMZ systems. This is important because the attempted access to DevAppServer did not trigger an EDR alert.

Finally, HSS should restart phishing awareness training and conduct regular tabletop exercises. These steps would help employees recognize suspicious emails and help the incident response team practice its response process before another real incident occurs.

Detection and Identification

The incident was detected on April 12, 2025, at 01:24 EST, after suspicious activity was identified from Workstation-23, a Finance department workstation with IP address 192.168.1.45. The evidence shows that the initial attack vector was a payroll-themed phishing email sent to a Finance user the night before. After the phishing email, Workstation-23 showed suspicious PowerShell activity, outbound communication to a suspicious external IP address, and interaction with sensitive internal systems.

Based on the evidence reviewed, Workstation-23 and HR-SQL01 are treated as compromised systems. Workstation-23 is compromised because it showed suspicious PowerShell activity, PsExec activity, outbound communication, and movement toward internal systems. HR-SQL01 is treated as compromised because Zeek logs confirm an SMB connection and an RDP session initiated from Workstation-23 to HR-SQL01 during the incident window. DevAppServer is treated as a high-risk system that was targeted, but it is not confirmed compromised because the evidence shows an attempted SSH login without successful access. At this stage, there is no confirmed evidence that sensitive data was accessed, altered, or exfiltrated, but the risk level is high because the activity involved systems connected to payroll, PII, and development assets.

Indicators of Compromise - See Appendix A

Log and Alert Analysis

The phishing email extract showed that a payroll-themed email was sent to accountant_jane@healthsecuresystems.com on April 11, 2025, at 22:05. The email used urgency around a “Q1 Payroll Adjustment File” to pressure the user into opening a suspicious link. This supports phishing as the initial access method.

The Windows Event Log showed several suspicious events on April 12, 2025. At 01:24:03, there was successful logon activity involving the former user account jcampbell from Workstation-23. At 01:24:18, the PsExec service was installed. At 01:24:39, the finance_user account executed a PowerShell command to download a payload from maliciousdomain.xyz. At 01:25:22, cmd.exe was used to run whoami, which can be used by an attacker to confirm the current user context or privileges.

The Zeek network logs showed that Workstation-23 interacted with sensitive systems shortly after the suspicious activity began. At 01:24:41, Workstation-23 made an SMB file share connection to HR-SQL01 at 192.168.1.88. At 01:24:55, an RDP session was initiated from Workstation-23 to HR-SQL01. Because both SMB and RDP activity were confirmed from the compromised workstation to HR-SQL01, HR-SQL01 is treated as compromised. At 01:25:03, Workstation-23 made an outbound HTTP connection to 45.77.33.88, a suspicious external destination. At 01:25:30, there was a DNS query for secure-download.com. At 01:26:09, Workstation-23 attempted an SSH connection to DevAppServer at 192.168.1.200.

The Snort alert log supported the same pattern of activity. Snort detected PsExec service installation activity from Workstation-23 to HR-SQL01, suspicious outbound PowerShell-related traffic from Workstation-23 to 45.77.33.88, and an SSH attempt from Workstation-23 to DevAppServer. These alerts support the conclusion that the attacker moved beyond the initially compromised workstation and attempted access toward additional sensitive systems.

The IT forensics update added additional concern around credential misuse. The update stated that jcampbell credentials appeared in a cached credential store on Workstation-23 and that further memory analysis was ongoing. The update also noted that the downloaded PowerShell payload was obfuscated and may include credential harvesting modules. The honeypot in the Development DMZ recorded a failed SSH attempt to DevAppServer using jcampbell. This failed login does not prove successful access to DevAppServer, but it does show attempted lateral movement or reconnaissance behavior.

Incident/Response Timeline - See Appendix B

Incident Scope

Workstation-23 is confirmed compromised, while HR-SQL01 is treated as compromised. Workstation-23, the Finance department workstation at 192.168.1.45, showed suspicious

PowerShell activity, outbound communication to a suspicious external IP address, PsExec-related activity, and credential-related concerns involving jcampbell.

HR-SQL01 at 192.168.1.88 is treated as compromised because Zeek logs confirmed an SMB connection and an RDP session initiated from Workstation-23 to HR-SQL01 during the incident window. HR-SQL01 is a high-risk asset because it contains payroll and PII database information. Although HR-SQL01 is treated as compromised, there is no confirmed evidence that payroll or PII data was accessed, altered, or exfiltrated.

DevAppServer at 192.168.1.200 was targeted through SSH activity. The attempted SSH login using jcampbell failed, and the honeypot alert indicates suspicious activity in the Development DMZ. DevAppServer is important because it hosts build artifacts and proprietary healthcare application source code. There is no evidence of successful access to DevAppServer, so it is not confirmed as compromised.

The users and accounts involved include accountant_jane, finance_user, and jcampbell. accountant_jane appears to be the phishing email recipient and likely initial target. finance_user was associated with suspicious PowerShell activity. jcampbell is a former employee account involved in suspicious activity, including cached credentials on Workstation-23 and failed SSH access to DevAppServer.

Severity Assessment

This incident is classified as High severity, P2. The reason is not that confirmed data theft has been proven, but that the attacker reached sensitive systems in the environment. The compromised systems include Workstation-23 and HR-SQL01, and DevAppServer was targeted. These systems are connected to payroll data, PII, and proprietary development resources.

There is currently no confirmed evidence of data exfiltration. The outbound HTTP connection to 45.77.33.88 may represent command-and-control traffic, but additional evidence would be needed to prove data theft. Examples of needed evidence would include large outbound transfers, compressed archive creation, file transfer logs, or database query logs showing sensitive data access.

Overall, the evidence shows a phishing-based compromise of Workstation-23, compromise of HR-SQL01, suspicious PowerShell execution, possible credential misuse, and attempted access toward DevAppServer. The immediate response actions were completed, including containment, eradication, recovery, phased restoration, MFA enforcement, and 30-day monitoring. The business impact could include payroll disruption, PII exposure, compliance concerns, operational disruption, and loss of client trust if similar weaknesses are not corrected.

Containment

The goal of containment is to stop the incident from spreading while preserving evidence for the investigation. In this incident, containment is especially important because Workstation-23 showed confirmed suspicious activity and interacted with sensitive systems. Workstation-23 and HR-SQL01 are treated as compromised systems. DevAppServer is treated as a high-risk system that was targeted, but it is not confirmed compromised because access was attempted without success. There is no confirmed evidence that sensitive data was accessed, altered, or exfiltrated.

Short-Term Containment Actions: 0–6 Hours

Workstation-23 was isolated from the network. This was appropriate because Workstation-23 was the source of the suspicious PowerShell activity, outbound communication, and connections toward sensitive internal systems. Keeping this workstation isolated helped prevent the attacker from continuing to use it as a launch point.

Outbound connections to the malicious domain were blocked. HSS also blocked the suspicious external IP address 45.77.33.88 and related suspicious domains, including maliciousdomain.xyz and secure-download.com. This helped prevent additional command-and-control communication or payload retrieval.

The jcampbell account and other risky accounts were disabled or locked pending investigation. This was necessary because jcampbell is a former employee account involved in suspicious activity, and those credentials appeared in the cached credential store on Workstation-23.

SMB, RDP, and SSH access to sensitive systems was temporarily restricted. This was important because Zeek and Snort logs showed Workstation-23 interacting with HR-SQL01 and attempting access to DevAppServer. Restricting these protocols helped reduce the risk of additional lateral movement.

Forensic evidence was preserved before major cleanup actions occurred. Logs, memory evidence, suspicious payloads, and endpoint artifacts were preserved so the team could understand what happened, what accounts were involved, and whether the attacker accessed additional systems.

Leadership, IT, legal, and compliance stakeholders were notified and coordinated with during containment. Because HR-SQL01 contains payroll and PII data, legal and compliance teams were included to assess potential regulatory exposure if data access or exposure was later confirmed.

Mid-Term Containment Actions: 6–24 Hours

HSS applied temporary strict firewall rules around HR-SQL01 and DevAppServer. These rules limited traffic to approved users, approved devices, and documented business needs only.

High-risk assets were placed under stricter access control while the investigation continued. This included systems that contain payroll data, PII, development artifacts, or administrative access. The goal was to protect sensitive systems while allowing critical operations to continue safely.

HSS monitored Zeek, Snort, Windows logs, EDR alerts, and honeypot activity to verify that containment was working. The team watched for repeat connections to 45.77.33.88, maliciousdomain.xyz, secure-download.com, HR-SQL01, and DevAppServer.

Known indicators of compromise were monitored across the environment. This included the PowerShell payload, PsExec service artifacts, suspicious outbound traffic, cached jcampbell credentials, failed logins, and unusual authentication activity.

HSS confirmed that Finance, HR, and Development operations could continue safely under temporary access restrictions. Business operations remained available where needed, but access stayed limited until affected systems were reviewed and validated.

Long-Term Containment Strategy

Long-term containment should focus on how HSS would respond if a similar breach occurs again in the future. The goal is to make future containment faster, more consistent, and more controlled so that one compromised workstation cannot easily spread to sensitive systems.

For future incidents, HSS should immediately isolate the confirmed compromised endpoint from the network. If the incident involves suspicious outbound traffic, HSS should also block known malicious IP addresses, domains, and URLs as soon as they are identified.

HSS should maintain pre-approved containment procedures for high-risk systems, including HR, Finance, Development DMZ, authentication services, and administrative systems. These procedures should define when to apply temporary firewall restrictions, when to isolate sensitive systems, and who has authority to approve containment actions.

HSS should enforce strict access control for SMB, RDP, and SSH during any future incident involving lateral movement. These protocols should be limited to approved users, approved systems, and required business workflows until the threat is contained and systems are validated.

HSS should use an incident-specific watchlist during future breaches. The watchlist should include affected systems, suspicious accounts, malicious IPs and domains, abnormal PowerShell activity, PsExec artifacts, failed logins, and any other indicators identified during the investigation.

HSS should also require immediate account review during future containment. Former employee accounts, inactive accounts, unnecessary privileges, and accounts showing suspicious activity should be locked until the investigation confirms they are safe to restore.

These future containment strategies are directly tied to the lessons from this incident. Workstation-23 showed the need for fast endpoint isolation. HR-SQL01 and DevAppServer showed the need for stronger controls around sensitive systems. The use of jcampbell credentials showed the need for immediate account review. Suspicious PowerShell, PsExec, SMB, RDP, SSH, and outbound traffic showed the need for repeatable containment procedures that can be activated quickly during a future breach.

Eradication

The goal of eradication is to remove the attacker's tools, access methods, and remaining artifacts from the environment. Eradication began after forensic evidence was preserved so HSS could understand what happened before systems were cleaned, rebuilt, or restored.

Root Cause Analysis

The root cause of this incident was a payroll-themed phishing email that led to the compromise of Workstation-23. The phishing email directed a Finance user to a suspicious file link, and shortly after, Workstation-23 showed suspicious PowerShell activity. The Windows Event Log showed that PowerShell was used to download a payload from maliciousdomain.xyz.

The incident succeeded because of multiple security weaknesses. First, the phishing email reached a Finance user and created an opportunity for initial compromise. Second, the former employee account jcampbell was involved in suspicious activity, and those credentials appeared in the cached credential store on Workstation-23. This showed risk from weak offboarding and credential management. Third, HSS had visibility gaps, including disabled PowerShell logging on about 30% of Windows machines and no EDR alert for the attempted DevAppServer access.

Short-Term Eradication Actions: 0–6 Hours

Malicious PowerShell activity on Workstation-23 was terminated. This step directly addressed the PowerShell activity used to download the suspicious payload.

The malicious payload was preserved, identified, extracted for analysis, and removed. This included saving a forensic copy, recording file details, and reviewing whether the payload included credential harvesting functionality.

PsExec service activity and related artifacts were identified on Workstation-23 and HR-SQL01. After evidence was preserved, unauthorized PsExec artifacts were removed because PsExec activity can support remote execution and lateral movement.

Affected systems were audited for persistence mechanisms and backdoors. This included checking startup items, scheduled tasks, unauthorized services, new user accounts, unusual remote access settings, and other signs that the attacker may have tried to maintain access.

Affected systems were returned to secure configuration settings. This included removing unauthorized changes, closing unnecessary access paths, and confirming that only approved services were running.

Mid-Term Eradication Actions: 6–24 Hours

HSS completed thorough EDR and antivirus scans on Workstation-23, HR-SQL01, DevAppServer, and other systems that showed matching indicators of compromise. The purpose was to confirm whether the malicious payload, PsExec artifacts, or related activity appeared elsewhere in the environment.

Event logs were reviewed to confirm threat absence. Windows logs, Zeek logs, Snort alerts, EDR events, and honeypot data were checked for repeat PowerShell activity, suspicious outbound connections, failed logins, or additional use of jcampbell.

Weak internal access controls were corrected. SMB, RDP, and SSH access were restricted to approved systems and users because these protocols were involved in suspicious activity toward HR-SQL01 and DevAppServer.

Inactive or unnecessary accounts were scanned, disabled, or removed. This was important because jcampbell was a former employee account involved in the incident, and the internal audit showed that four former employee AD accounts were still active.

Bitdefender EDR policies were updated and validated across Windows, Linux, and DMZ systems. This addressed the visibility gap where the attempted DevAppServer access did not trigger an EDR alert.

Overall, eradication removed the immediate malicious artifacts and closed the access paths that allowed the incident to expand beyond the initial workstation. PowerShell activity and the malicious payload were addressed because they were central to the initial compromise. PsExec artifacts and weak SMB/RDP/SSH access were addressed because they supported movement toward sensitive systems. Inactive accounts and exposed credentials were addressed because jcampbell credentials were involved in the incident. EDR policy updates were completed because endpoint visibility gaps limited detection during the attack.

Recovery

The goal of recovery is to restore affected systems to normal operation while confirming that they are clean, functional, and secure. Recovery began after containment and eradication actions were completed or sufficiently controlled. In this incident, recovery focused on Workstation-23 and HR-SQL01 as compromised systems, while also validating DevAppServer because it was targeted during the incident.

Restoration Process

Workstation-23 needed to be rebuilt or fully cleaned before reuse. Because this workstation showed suspicious PowerShell activity, outbound communication to a suspicious external IP address, PsExec activity, and cached jcampbell credentials, the safest recovery approach was to restore the workstation from a trusted, clean baseline. Required business software was reinstalled from approved sources only.

Affected systems and data were reviewed against trusted backups and available system records to verify integrity. Backups were checked before use to confirm they were created before the compromise and did not contain malicious artifacts. Where restoration was required, restored data was compared against known-good records to confirm accuracy and integrity.

HR-SQL01 was validated before normal access was fully restored. This was necessary because Zeek logs confirmed SMB and RDP activity from Workstation-23 to HR-SQL01. Although HR-SQL01 is treated as compromised, there is no confirmed evidence that payroll or PII data was accessed, altered, or exfiltrated. Recovery validation included checking database integrity, reviewing authentication activity, and confirming that expected payroll and HR functions operated normally.

DevAppServer was also validated before normal access was restored. The evidence showed failed SSH activity toward the Development DMZ server using jcampbell. Even though successful access was not confirmed, DevAppServer contains development artifacts and proprietary healthcare application resources, so it was reviewed for unauthorized logins, changed files, unusual processes, and unexpected services.

Critical services were resumed in deliberate phases. Finance, HR, and Development functions were prioritized based on business need, but access remained limited until each system was verified as clean, stable, and secure.

Verification Steps

Before systems returned to normal operation, HSS completed several verification steps.

First, Workstation-23 passed endpoint security scans using updated EDR and antivirus signatures. These scans confirmed that the PowerShell payload, PsExec artifacts, suspicious processes, and unauthorized services were no longer present.

Second, system logs were reviewed to confirm that suspicious activity had stopped. This included checking for repeat PowerShell execution, outbound communication to 45.77.33.88, DNS activity involving maliciousdomain.xyz or secure-download.com, and new SMB, RDP, or SSH activity from Workstation-23.

Third, affected user accounts were validated before access was restored. Passwords for affected accounts were reset, the jcampbell account remained disabled, and inactive accounts stayed locked until access reviews were completed.

Fourth, HR-SQL01 was checked for unauthorized access or data changes. This included reviewing Windows logs, database logs where available, file access records, and available SQL query logs. The goal was to confirm whether payroll or PII data was accessed, changed, or exported.

Fifth, DevAppServer was checked for failed or successful SSH attempts, changed files, unexpected services, and unusual user activity. This was important because the attempted access to DevAppServer did not trigger an EDR alert, which required additional validation.

Finally, restored systems were tested for both functionality and security. This confirmed that normal business processes worked, critical patches were applied, unnecessary services were disabled, and temporary access restrictions remained in place where needed.

Post-Recovery Monitoring

After systems were restored, HSS began enhanced monitoring for at least 30 days. This monitoring focused on the affected IP addresses, user accounts, systems, and indicators of compromise identified during the investigation.

Monitoring included Workstation-23, HR-SQL01, DevAppServer, the jcampbell account, the finance_user account, and the phishing recipient account. HSS also monitored for repeat activity involving 45.77.33.88, maliciousdomain.xyz, secure-download.com, PowerShell payload activity, PsExec artifacts, SMB, RDP, and SSH.

Zeek, Snort, Windows logs, Bitdefender EDR, and honeypot alerts were reviewed during the monitoring period. HSS also expanded monitoring rules and watchlists for the known IoCs from this incident.

HSS enforced multi-factor authentication for accounts with access to sensitive systems, especially Finance, HR, Development, and administrative accounts. This reduced the risk that stolen or cached credentials could be reused after recovery.

HSS also updated incident response runbooks based on the findings from this incident. These updates helped capture lessons learned from the phishing attack, credential misuse, PowerShell activity, PsExec activity, and attempted lateral movement.

Recovery was considered complete after Workstation-23 was rebuilt or confirmed clean, HR-SQL01 and DevAppServer were validated, affected accounts were reset or disabled, critical patches were applied, restored systems passed functionality and security testing, and 30-day monitoring was initiated.

Overall, the recovery process was deliberate and phased. HSS avoided rushing systems back into production before they were validated. This approach protected business continuity while reducing the risk of reinfection, repeated credential misuse, or additional lateral movement.

Post-Incident Review

The post-incident review focuses on what HSS learned from this incident and how the response process should be improved. The incident shows that HSS has useful detection capabilities, but also several gaps in account management, visibility, training, and incident response readiness.

What Worked Well

One successful part of the response is that suspicious activity was detected by existing security tools. Snort identified suspicious activity from Workstation-23, Zeek showed network traffic toward HR-SQL01 and DevAppServer, Windows Event Logs showed suspicious PowerShell and PsExec activity, and the honeypot identified unauthorized activity in the Development DMZ. These tools helped the team identify that the incident involved more than a simple phishing email.

Another strength is that the response team completed immediate containment actions quickly. Workstation-23 was isolated, malicious IPs and domains were blocked, risky accounts were disabled, forensic evidence was preserved, and Legal and Compliance were engaged because of the potential payroll and PII risk. These actions helped reduce the risk of further spread and supported the investigation.

The use of multiple evidence sources is also a strength. The investigation included phishing email evidence, Windows logs, Zeek logs, Snort alerts, asset inventory, EDR information, honeypot data, and the IT forensics update. This gave HSS a clearer view of the incident timeline and supported evidence-based decision-making.

The recovery process was also handled in a controlled manner. Affected systems were validated, Workstation-23 was rebuilt or cleaned before reuse, critical patches were applied, services were restored in phases, multi-factor authentication was enforced, and 30-day monitoring was initiated.

Areas for Improvement

The first major area for improvement is employee offboarding. The incident involved the former employee account jcampbell, and those credentials appeared in the cached credential store on Workstation-23. HSS also has a known issue with manual de-provisioning and active former employee accounts. This creates a serious risk because stale credentials may be reused during an attack.

The second area for improvement is visibility. HSS relies on separate tools instead of a centralized SIEM. For a small incident response team made up of a SOC Analyst, Forensics Specialist, and IT Operations Lead, manually connecting evidence from separate sources can slow down detection, investigation, and response.

The third area for improvement is endpoint monitoring coverage. No EDR alert triggered for the attempted DevAppServer access. This suggests that HSS should review EDR coverage and policies across Linux, DMZ, and other critical systems.

The fourth area for improvement is phishing readiness. The initial attack vector is a payroll-themed phishing email sent to a Finance user. HSS has not conducted recent phishing simulations, which may reduce employee readiness to identify and report suspicious emails.

The fifth area for improvement is incident response readiness. HSS has a basic incident response playbook, but it has not conducted recent tabletop exercises. Without this practice, a small response team may have difficulty coordinating roles, escalation, legal/compliance communication, and recovery decisions during a real incident.

Updated IR Plan Recommendations

The HSS incident response plan should be updated to include specific playbooks for phishing, credential misuse, PowerShell abuse, PsExec activity, and lateral movement attempts. These playbooks should define response steps, evidence to collect, escalation points, containment actions, eradication steps, recovery validation, and communication expectations.

The plan should also include a formal account review process during incident response. If a former employee account or cached credential is involved, the team should immediately check for related active accounts, stale access, and additional authentication attempts.

The IR plan should include a clear communication process for leadership, IT, legal, HR, compliance, and communications teams. This is important because HR-SQL01 contains payroll and PII data, which could create reporting or compliance obligations if exposure is later confirmed.

Finally, the plan should require a post-incident timeline, evidence summary, containment summary, eradication summary, recovery validation, and lessons learned review after each significant incident. This will help HSS turn each incident into a practical improvement opportunity.

Continuous Improvement

The continuous improvement plan focuses on sustainable changes that can strengthen HSS's long-term security posture. These recommendations are based on the weaknesses identified during the incident: manual offboarding, lack of centralized visibility, endpoint monitoring gaps, phishing exposure, access control concerns, and limited incident response practice.

Process Refinements

HSS should automate employee offboarding so accounts are disabled immediately when an employee leaves the organization. This process should include HR, IT, and security checks to confirm that user accounts, VPN access, email access, administrative privileges, and application

access are removed. Regular access reviews should also be performed to identify stale accounts, unnecessary privileges, and cached credential risks.

HSS should update the incident response playbook. The updated playbook should include detailed procedures for phishing-based compromise, credential misuse, suspicious PowerShell activity, PsExec activity, compromised HR systems, and lateral movement attempts. Each procedure should clearly define who is responsible, what evidence should be preserved, what systems should be checked, when containment actions should begin, and when leadership or compliance teams should be notified.

Quarterly tabletop exercises should be scheduled to test the updated plan. These exercises should include realistic scenarios involving phishing, compromised credentials, HR data risk, DMZ system access attempts, and coordinated containment, eradication, and recovery actions. This will help the small IR team practice decision-making before another real incident occurs.

New Security Measures

HSS should implement a SIEM or centralized log review process. Centralizing Snort, Zeek, Windows logs, Bitdefender EDR, honeypot alerts, and authentication logs would help the team identify patterns faster and reduce investigation delays.

HSS should standardize and audit EDR policies across Windows, Linux, and DMZ systems. This is important because no EDR alert triggered for the attempted DevAppServer access. Consistent EDR coverage would improve detection of lateral movement and suspicious access attempts.

PowerShell logging should be enabled across all Windows machines. Since PowerShell was used to download the suspicious payload, full PowerShell visibility is important for future detection and investigation.

HSS should strengthen network segmentation and access control rules. SMB, RDP, and SSH traffic should be limited to approved users, approved systems, and documented business needs. This would reduce the chance that one compromised workstation can reach sensitive systems like HR-SQL01 or DevAppServer.

HSS should implement stronger email security controls, such as advanced phishing detection, URL scanning, attachment analysis, and email banner warnings for suspicious messages. These controls would help reduce the chance that a phishing email reaches a user and becomes the entry point for another incident.

Training Recommendations

HSS should restart phishing awareness training and phishing simulations. Training should focus on urgent department-themed emails, suspicious links, attachment risks, and how employees should report suspicious messages.

Role-based training should also be provided. Finance users should receive training on payroll-themed phishing risks. IT and security staff should receive training on incident escalation, log review, evidence preservation, containment execution, and credential misuse investigations. Leadership should receive training on incident decision-making, business risk, and compliance communication.

HSS should train the incident response team on using the updated playbook and responding to incidents involving credential reuse, lateral movement, compromised HR systems, and sensitive data risk. This will help the team respond more consistently and reduce confusion during future incidents.

Conclusion

The incident at HealthSecure Systems was a phishing-based compromise involving Workstation-23, a Finance department workstation. The evidence showed suspicious PowerShell activity, outbound communication to a suspicious external IP address, PsExec activity, and interaction with sensitive internal systems. The incident also involved credential misuse connected to the former employee account jcampbell.

Workstation-23 is confirmed compromised, while HR-SQL01 is treated as compromised. HR-SQL01 is treated as compromised because Zeek logs confirmed an SMB connection and an RDP session initiated from Workstation-23 to HR-SQL01 during the incident window. DevAppServer was targeted through a failed SSH login, but it is not confirmed compromised. At this time, there is no confirmed evidence that payroll data, PII, or development assets were accessed, altered, or exfiltrated. However, the business risk remains high because the incident involved systems connected to payroll, employee data, and proprietary development resources.

Summary of Actions

During the incident response process, HSS completed key investigative, containment, eradication, and recovery actions. The most important actions included:

- Reviewed key evidence, including Snort alerts, Zeek logs, Windows Event Logs, phishing email evidence, asset inventory data, and forensic updates.
- Identified Workstation-23 and HR-SQL01 as compromised systems, and identified DevAppServer as targeted but not confirmed compromised.
- Isolated Workstation-23, blocked malicious IPs and domains, disabled risky accounts, preserved forensic evidence, and coordinated with Legal and Compliance.
- Removed malicious PowerShell activity, PsExec service activity, and the suspicious payload.
- Validated affected systems through EDR scans, event log review, data integrity checks, patching, and functional/security testing.
- Restored services in deliberate phases, enforced multi-factor authentication, began 30-day monitoring, and updated IR runbooks based on findings.

Key Recommendations

The most critical improvements needed to strengthen HSS's security posture are:

- Automate employee offboarding and perform regular access reviews to reduce risk from stale or former employee accounts.
- Implement centralized logging through a SIEM or similar process to improve visibility and reduce investigation time.
- Standardize EDR coverage across Windows, Linux, and DMZ systems, and enable PowerShell logging across all Windows endpoints.
- Strengthen phishing readiness through awareness training, phishing simulations, and stronger email security controls.
- Improve network segmentation and access controls for sensitive HR, Finance, Development, and administrative systems.
- Update the incident response playbook and conduct regular tabletop exercises.

Overall, this incident shows that HSS has useful detection tools in place, but the organization needs stronger account management, centralized visibility, endpoint monitoring, phishing defenses, network segmentation, and incident response readiness. Addressing these gaps will reduce the chance of recurrence, improve response speed, and help protect HSS's operations, compliance posture, and client trust.

Appendix A

Indicators of Compromise:

IoC Category	Indicator	Why It Matters
Network IoC	192.168.1.45 → 45.77.33.88	Workstation-23 connected to a suspicious external IP address.
Network IoC	maliciousdomain.xyz	Domain used in the PowerShell command to download the suspicious payload.
Network IoC	secure-download.com	Domain tied to the suspicious payroll-themed email link.
Network IoC	192.168.1.45 → 192.168.1.88	Workstation-23 connected with HR-SQL01, a sensitive HR database server.
Network IoC	192.168.1.45 → 192.168.1.200	Workstation-23 attempted access toward DevAppServer in the Development DMZ.
Host-Based IoC	Workstation-23 / 192.168.1.45	Confirmed compromised Finance workstation.
Host-Based IoC	HR-SQL01 / 192.168.1.88	HR server treated as compromised; contains payroll and PII data.
Host-Based IoC	PowerShell payload download	Indicates suspicious script execution on the compromised workstation.
Host-Based IoC	Obfuscated payload	May hide malicious activity, including possible credential harvesting.
Host-Based IoC	Psexec service installed	Possible sign of lateral movement or remote execution activity.
Host-Based IoC	cmd.exe /c whoami	Command commonly used to check the current user or privilege level.
Account IoC	jcampbell	Former employee account involved in suspicious activity.
Account IoC	Cached jcampbell credentials on Workstation-23	Indicates possible credential exposure or reuse risk.
Account IoC	Failed SSH login using jcampbell	Attempted access to the Development DMZ server using former employee credentials.
Account IoC	finance_user	Account used during suspicious PowerShell activity.
Account IoC	accountant_jane	Recipient of the phishing email and likely initial target.

Appendix B

Incident/Response Timeline:

Date / Time	Source	Event
Apr. 11, 2025, 22:05:00	Phishing Email Extract	Payroll-themed email sent to accountant_jane containing a suspicious file link: secure-download.com.
Apr. 12, 2025, 1:24:03	Windows Event Log	Successful logon activity by user jcampbell from 192.168.1.45, Workstation-23.
Apr. 12, 2025, 1:24:10	Snort Alert Log	PsExec service install detected from Workstation-23 to 192.168.1.88, HR-SQL01.
Apr. 12, 2025, 1:24:18	Windows Event Log	Service PsExecsvc installed by NT AUTHORITY\SYSTEM.
Apr. 12, 2025, 1:24:39	Windows Event Log	PowerShell command executed by finance_user to download a payload from maliciousdomain.xyz.
Apr. 12, 2025, 1:24:41	Zeek Log	SMB file share connection over port 445 from Workstation-23 to HR-SQL01.
Apr. 12, 2025, 1:24:55	Zeek Log	RDP session initiated over port 3389 from Workstation-23 to HR-SQL01.
Apr. 12, 2025, 1:25:03	Zeek Log	Outbound HTTP connection from Workstation-23 to suspicious IP address 45.77.33.88.
Apr. 12, 2025, 1:25:22	Windows Event Log	cmd.exe /c whoami command executed by finance_user.
Apr. 12, 2025, 1:25:30	Zeek Log	DNS query from Workstation-23 for secure-download.com.
Apr. 12, 2025, 1:25:55	Windows Event Log	explorer.exe launched by finance_user.
Apr. 12, 2025, 1:26:09	Zeek Log	SSH login attempt over port 22 from Workstation-23 to 192.168.1.200, DevAppServer.
Apr. 12, 2025, 1:26:09	Snort Alert Log	Outbound PowerShell command detected from Workstation-23 to 45.77.33.88.
Apr. 12, 2025, 1:27:03	Snort Alert Log	SSH attempt to DMZ server detected from Workstation-23 to DevAppServer.
Apr. 12, 2025, 2:11:34	Honeypot	Failed SSH login to DevAppServer from Workstation-23 using jcampbell credentials.
Apr. 12, 2025, 3:01:43	IR Team Action	Containment began. Workstation-23 was

	Log	isolated from the network.
Apr. 12, 2025, 3:08:16	IR Team Action Log	Malicious IPs and domains were blocked, including 45.77.33.88, maliciousdomain.xyz, and secure-download.com.
Apr. 12, 2025, 3:17:29	IR Team Action Log	The jcampbell account and other risky accounts were disabled pending investigation.
Apr. 12, 2025, 3:26:52	IR Team Action Log	Forensic evidence was preserved, including logs, endpoint artifacts, payload evidence, and relevant system data.
Apr. 12, 2025, 3:41:07	IR Team Action Log	Legal and Compliance were coordinated because the incident involved payroll, PII, and potential regulatory exposure.
Apr. 12, 2025, 4:13:36	IT Operations Log	Temporary firewall restrictions were applied for HR and DMZ systems.
Apr. 12, 2025, 4:38:14	IT Operations Log	High-risk assets, including HR-SQL01 and related sensitive data systems, were isolated or placed under stricter access control.
Apr. 12, 2025, 5:06:48	IT Operations Log	Strict access controls were enforced for SMB, RDP, and SSH traffic.
Apr. 12, 2025, 5:34:22	SOC Monitoring Log	Zeek and Snort monitoring confirmed no immediate repeat outbound traffic to the known malicious destinations.
Apr. 12, 2025, 6:02:57	Operations Status Log	Critical operations were confirmed to be continuing safely under temporary restrictions.
Apr. 12, 2025, 6:18:33	Eradication Action Log	Malicious PowerShell activity on Workstation-23 was terminated.
Apr. 12, 2025, 6:42:19	Eradication Action Log	The rogue PsExecsvc activity was removed from HR-SQL01 after evidence preservation.
Apr. 12, 2025, 7:03:26	Forensics Log	The malicious payload was identified and extracted for analysis.
Apr. 12, 2025, 7:19:58	Security Review Log	Systems were audited for backdoors, persistence mechanisms, unauthorized services, and suspicious account activity.
Apr. 12, 2025, 7:41:05	IT Operations Log	Affected systems were reset to secure configuration settings.
Apr. 12, 2025, 8:12:44	EDR Log	Thorough EDR scans were started to validate system cleanliness across affected and high-risk systems.
Apr. 12, 2025, 9:06:31	Log Review Record	Event logs were reviewed to confirm threat absence and identify any repeat activity.

Apr. 12, 2025, 10:14:55	IT Operations Log	Weak internal access controls were corrected, including restrictions for SMB, RDP, and SSH.
Apr. 12, 2025, 11:27:18	Access Review Log	Inactive accounts were scanned and disabled, including unnecessary former employee accounts.
Apr. 12, 2025, 12:46:09	EDR Administration Log	Bitdefender EDR policies were updated and validated across Windows, Linux, and DMZ systems.
Apr. 12, 2025, 13:38:42	Recovery Action Log	Data integrity of affected servers was verified against trusted backups and available system records.
Apr. 12, 2025, 14:22:17	Recovery Action Log	Workstation-23 was rebuilt or cleaned before reuse.
Apr. 12, 2025, 15:08:51	Patch Management Log	Critical system patches were applied to affected and high-risk systems.
Apr. 12, 2025, 16:31:24	Validation Log	Restored systems were tested for function and security.
Apr. 12, 2025, 17:26:39	Recovery Action Log	Systems were restored without known vulnerabilities remaining from the incident.
Apr. 12, 2025, 18:44:03	Operations Status Log	Services were resumed in deliberate phases.
Apr. 12, 2025, 19:12:28	SOC Monitoring Log	Monitoring was expanded for repeat activity involving affected systems, accounts, and IoCs.
Apr. 12, 2025, 20:05:47	Identity Management Log	Multi-factor authentication was enforced for sensitive and high-risk accounts.
Apr. 12, 2025, 21:33:11	SOC Monitoring Log	Thirty-day strict monitoring of affected IPs, accounts, and known IoCs began.
Apr. 12, 2025, 22:18:59	IR Documentation Log	IR runbooks were updated based on findings from the incident.